

A Practical Attack to De-Anonymize Social Network Users

Summary

The paper introduces a novel de-anonymization attack that exploits group membership information on social networks. Using history stealing techniques, a malicious website can probe a visitor's browser history for URLs that indicate membership in specific groups. By combining this partial group fingerprint with pre-collected membership data from the social network, the attacker can uniquely identify the visitor or significantly reduce the candidate set. The authors demonstrate the attack on Xing, Facebook, and LinkedIn, showing that about 42% of Xing users who use groups can be uniquely identified. They also discuss mitigation strategies and note that Xing fixed the vulnerability within four days after responsible disclosure.

Strengths

- Social Network, Browser History, and Attacker Models Mathematical Definitions
- Novel combination of history stealing and group membership data
- Empirical validation on real social networks with large user bases

Weaknesses

- Relies on users not clearing browser history
- Group membership data degrades over time
- Server-side mitigation (randomized URLs)

Comments On Strengths & Weaknesses

For starters the paper starts by giving mathematical definition of both social networks and browser history. Their definition of social networks is a series of sets and a graph $\mathbf{G}(V, E)$ where V are the users and two users share an edge $e \in E$ iff these users are friends. Additionally, social networks tend to have groups or pages which was defined as G and a group $g \in G$ has a set of users $v \in V \wedge v \in g$ (unless the group is empty in which case $\forall v \in V, v \notin g$). Then the paper defined membership in a group for a user $v \in V$ as $\Gamma(v) := (\Gamma_g(v))_{g \in G}$ and that $\Gamma_g(v) = 1$ when $v \in g$ and otherwise equal to 0. As for browser history, the set β_v is the set of urls (ϕ_p which is the url used to load page p) that were used by a user v . Some histories expire after a certain time τ which vary by the browser. Now for their definition of an attacker model, the attacker has some computation function σ_v for a victim v where $\sigma_v(\phi_p) = 1$ iff $\phi_p \in \beta_v$ otherwise 0. By using these definitions, the paper cleverly combines two well-known techniques, history stealing and group membership enumeration, into a powerful de-anonymization attack. History stealing alone only reveals which generic sites a user visited, not who the user is. By mapping visited group URLs to pre-crawled membership lists, the attacker learns the victim's identity. This is a novel insight and the empirical results are convincing. The authors crawled more than 1.8 million Xing users and 43 million Facebook group members with modest resources, showing the attack is practical and low-cost. However, the attack has clear weaknesses. It depends on users not clearing their browser history. Many

people do clear history or use private browsing modes, especially as awareness of tracking increases. The paper acknowledges this but does not quantify how many users are protected by such habits. Another weakness is data degradation. Group memberships change over time as people join and leave. The authors measured that after 18 days, group sizes changed by up to 50% for some groups. An attacker must crawl frequently to maintain accuracy, which increases cost and risk of detection. Finally, the server-side mitigation of adding random tokens to URLs, while effective, breaks legitimate functionality like bookmarking specific group pages. This tradeoff between security and usability is not fully explored. Overall, the attack is elegant and practical, but its real-world impact depends on user behavior and the willingness of social networks to accept usability costs.